

# Compliance Audit: Acme Corporation

|                   |                       |                 |                               |
|-------------------|-----------------------|-----------------|-------------------------------|
| Company:          | Acme Corporation      | Audit Standard: | EU GDPR (Regulation 2016/679) |
| Policy Document:  | Global Privacy Policy | Audit Date:     | August 17, 2026               |
| Evaluated Groups: | 13                    | Risk Level:     | CRITICAL RISK                 |

## Overall Compliance Summary

|                  |           |               |         |             |                       |
|------------------|-----------|---------------|---------|-------------|-----------------------|
| 45.5%            | 3         | 4             | 0       | 0           | 4                     |
| Compliance Score | Fully Met | Partially Met | Not Met | Conflicting | Insufficient Evidence |

## Executive Overview

This GDPR Compliance Audit evaluated **13 requirement groups** spanning **21 sub-obligations** across the General Data Protection Regulation. The assessment determined an overall compliance posture of **45.5%** with a designated risk classification of **CRITICAL RISK**.

### Key Audit Findings:

- **Fully Satisfied:** 3 requirement groups clearly demonstrated compliance.
- **Partial Gaps:** 4 requirement groups exhibit partial policy coverage requiring formal procedural additions.
- **Non-Compliant / Unaddressed:** 0 requirement groups lacked mandatory policy disclosures or operational commitments.
- **Conflicting Directives:** 0 groups contain policy language directly contradicting GDPR standards.

# Chapter-by-Chapter Compliance Breakdown

Structured view of compliance readiness across the 11 GDPR thematic chapters.

| Chapter      | Chapter Name                                  | Articles   | Evaluated Groups | Status                         |
|--------------|-----------------------------------------------|------------|------------------|--------------------------------|
| Chapter I    | General Provisions                            | Art. 1–4   | 0                | No Direct<br>Obligation Groups |
| Chapter II   | Principles                                    | Art. 5–11  | 13               | PARTIALLY MET                  |
| Chapter III  | Rights of the Data Subject                    | Art. 12–23 | 0                | No Direct<br>Obligation Groups |
| Chapter IV   | Controller and Processor                      | Art. 24–43 | 0                | No Direct<br>Obligation Groups |
| Chapter V    | Transfers of Personal Data to Third Countries | Art. 44–49 | 0                | No Direct<br>Obligation Groups |
| Chapter VI   | Independent Supervisory Authorities           | Art. 51–59 | 0                | No Direct<br>Obligation Groups |
| Chapter VII  | Co-operation and Consistency                  | Art. 60–76 | 0                | No Direct<br>Obligation Groups |
| Chapter VIII | Remedies, Liability and Penalties             | Art. 77–84 | 0                | No Direct<br>Obligation Groups |
| Chapter IX   | Specific Processing Situations                | Art. 85–91 | 0                | No Direct<br>Obligation Groups |
| Chapter X    | Delegated Acts and Implementing Acts          | Art. 92–93 | 0                | No Direct<br>Obligation Groups |
| Chapter XI   | Final Provisions                              | Art. 94–99 | 0                | No Direct<br>Obligation Groups |

# Detailed Requirement Gap Analysis

Granular sub-obligation verdicts grounded in retrieved policy evidence.

## Group 5.1.f — Integrity and confidentiality (Article 5) | MET (Confidence: 95%)

| Obligation ID | Verdict & Confidence    | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|---------------|-------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5.1.f.1       | <b>MET</b><br>Conf: 95% | <b>Analysis:</b> Policy explicitly states implementation of industry-standard technical measures (TLS 1.3 encryption in transit, AES-256 encryption at rest) and organizational measures (MFA access control, quarterly audits, annual penetration testing) to protect against unauthorized access, loss, or damage.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:9):</i> "We implement industry-standard technical and organisational measures to protect your personal data against unauthorised access, loss, destruction, or alteration. - All data in transit is encrypted using TLS 1.3 - All data at rest is encrypted using AES-256 - Access to production systems is restricted to authorised personnel only via MFA - We conduct quarterly internal security audits - Penetration testing is conducted annually by a third-party security firm" |

## Group 5.1.quality\_retention — Accuracy and storage limitation (Article 5) | PARTIALLY\_MET (Confidence: 75%)

**Identified Gap / Finding:** Policy provides right to correction but lacks explicit 'prompt' timeframe. Retention periods are defined with legal exceptions but safeguards for extended retention are not explicitly stated.

| Obligation ID           | Verdict & Confidence              | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-------------------------|-----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5.1.quality_retention.1 | <b>PARTIALLY_MET</b><br>Conf: 75% | <b>Analysis:</b> Policy provides right to correction but lacks explicit 'prompt' timeframe. Retention periods are defined with legal exceptions but safeguards for extended retention are not explicitly stated.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:6):</i> "If any personal data we hold about you is inaccurate or incomplete, you may request that we correct or update it."<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:4):</i> "We retain personal data only for as long as necessary to fulfil the purposes outlined in this policy." |

## Group 5.1.handling — Lawfulness, fairness, transparency, purpose limitation and minimisation (Article 5) | MET (Confidence: 92%)

| Obligation ID  | Verdict & Confidence    | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|----------------|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5.1.handling.1 | <b>MET</b><br>Conf: 92% | <b>Analysis:</b> Policy explicitly states lawful bases (contractual, legitimate interests, legal obligation, consent), transparent handling (consent withdrawal rights), specific purposes (fraud prevention, security, product improvement), and compatibility of processing. Data minimization is addressed through retention policies.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "We process personal data only when we have a valid legal basis to do so. The legal bases we rely on are: Contractual necessity, Legitimate interests, Legal obligation, Consent."<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "Consent — for marketing communications and optional analytics (you can withdraw at any time)"<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "We do not further process in a manner incompatible with those purposes"<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:4):</i> "We retain personal data only for as long as necessary to fulfil the purposes outlined in this policy" |

## Group 5.2 — Accountability (Article 5) | PARTIALLY\_MET (Confidence: 65%)

**Identified Gap / Finding:** Policy mentions data retention periods and legal bases for processing, which support accountability. However, there is no explicit evidence of records or documentation demonstrating compliance with Art. 5(1).

| Obligation ID | Verdict & Confidence              | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|---------------|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5.2.1         | <b>PARTIALLY_MET</b><br>Conf: 65% | <b>Analysis:</b> Policy mentions data retention periods and legal bases for processing, which support accountability. However, there is no explicit evidence of records or documentation demonstrating compliance with Art. 5(1).<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:5):</i> "Transaction records and invoices are retained for 7 years in compliance with Indian tax laws..."<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:4):</i> "We retain personal data only for as long as necessary to fulfil the purposes outlined in this policy." |

#### Group 6.4 — Compatibility assessment for further processing on a new purpose (Article 6) | **INSUFFICIENT\_EVIDENCE** (Confidence: 100%)

**Identified Gap / Finding:** The policy documents do not mention or describe a compatibility assessment process considering factors like the link to the original purpose, collection context, data nature, consequences, or safeguards when further processing data for a new purpose without consent or a qualifying law.

| Obligation ID | Verdict & Confidence                       | Reason & Evidence Quote                                                                                                                                                                                                                                                                                         |
|---------------|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 6.4.1         | <b>INSUFFICIENT_EVIDENCE</b><br>Conf: 100% | <b>Analysis:</b> The policy documents do not mention or describe a compatibility assessment process considering factors like the link to the original purpose, collection context, data nature, consequences, or safeguards when further processing data for a new purpose without consent or a qualifying law. |

#### Group 6.3 — Legal-basis grounding for legal-obligation and public-task processing (Article 6) | **PARTIALLY\_MET** (Confidence: 85%)

**Identified Gap / Finding:** The policy lists 'Legal obligation — to comply with applicable laws and regulations' as a legal basis, but it does not specifically identify the particular laws establishing the legal basis for processing other than mentioning Indian tax laws (Income Tax Act, 1961 and GST Act, 2017) in the context of retaining financial records.

| Obligation ID | Verdict & Confidence              | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|---------------|-----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 6.3.1         | <b>PARTIALLY_MET</b><br>Conf: 85% | <b>Analysis:</b> The policy lists 'Legal obligation — to comply with applicable laws and regulations' as a legal basis, but it does not specifically identify the particular laws establishing the legal basis for processing other than mentioning Indian tax laws (Income Tax Act, 1961 and GST Act, 2017) in the context of retaining financial records.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "Legal obligation — to comply with applicable laws and regulations"<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:5):</i> "Transaction records and invoices are retained for 7 years in compliance with Indian tax laws (Income Tax Act, 1961 and GST Act, 2017)." |

#### Group 6.1 — Lawful basis for processing (Article 6) | **MET** (Confidence: 95%)

| Obligation ID | Verdict & Confidence              | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                 |
|---------------|-----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 6.1.a         | <b>MET</b><br>Conf: 100%          | <b>Analysis:</b> The policy explicitly identifies consent as a lawful basis for processing.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "Consent — for marketing communications and optional analytics (you can withdraw at any time)"                                                                                                    |
| 6.1.b         | <b>MET</b><br>Conf: 100%          | <b>Analysis:</b> The policy identifies contractual necessity and legal obligation as valid legal bases for processing.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "Contractual necessity — to provide the Services you have signed up for - Legal obligation — to comply with applicable laws and regulations"                           |
| 6.1.c         | <b>NOT_MET</b><br>Conf: 100%      | <b>Analysis:</b> The provided policy evidence does not mention vital interests or public interest/official authority as lawful bases for processing.                                                                                                                                                                                                    |
| 6.1.d         | <b>PARTIALLY_MET</b><br>Conf: 80% | <b>Analysis:</b> The policy identifies legitimate interests as a lawful basis, but does not explicitly describe how those interests are balanced against the data subject's fundamental rights and freedoms.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "Legitimate interests — for fraud prevention, security, and product improvement" |

#### Group 7.1 — Ability to demonstrate consent (Article 7) | **INSUFFICIENT\_EVIDENCE** (Confidence: 100%)

**Identified Gap / Finding:** The policy states that consent is relied on for marketing communications and optional analytics, but it does not describe how consent is recorded, tracked, or evidenced by the controller.

| Obligation ID | Verdict & Confidence                       | Reason & Evidence Quote                                                                                                                                                                                      |
|---------------|--------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7.1.1         | <b>INSUFFICIENT_EVIDENCE</b><br>Conf: 100% | <b>Analysis:</b> The policy states that consent is relied on for marketing communications and optional analytics, but it does not describe how consent is recorded, tracked, or evidenced by the controller. |

#### Group 7.2 — Clear presentation of consent requests (Article 7) | **INSUFFICIENT\_EVIDENCE** (Confidence: 100%)

**Identified Gap / Finding:** The supplied policy evidence mentions consent as a legal basis for processing marketing communications and optional analytics, but contains no text addressing whether bundled consent requests are presented distinguishably, intelligibly, and in plain language. The supplied policy evidence contains no mention of whether consent obtained through non-compliant bundled declarations is non-binding.

| Obligation ID | Verdict & Confidence                       | Reason & Evidence Quote                                                                                                                                                                                                                                                              |
|---------------|--------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7.2.1         | <b>INSUFFICIENT_EVIDENCE</b><br>Conf: 100% | <b>Analysis:</b> The supplied policy evidence mentions consent as a legal basis for processing marketing communications and optional analytics, but contains no text addressing whether bundled consent requests are presented distinguishably, intelligibly, and in plain language. |
| 7.2.2         | <b>INSUFFICIENT_EVIDENCE</b><br>Conf: 100% | <b>Analysis:</b> The supplied policy evidence contains no mention of whether consent obtained through non-compliant bundled declarations is non-binding.                                                                                                                             |

#### Group 7.4 — Freely given consent assessment (Article 7) | **INSUFFICIENT\_EVIDENCE** (Confidence: 80%)

**Identified Gap / Finding:** The policy mentions that consent is used for marketing communications and optional analytics, but it lacks specific statements addressing whether the performance of a contract or service provision is conditioned on consent to processing that is not necessary for the contract.

| Obligation ID | Verdict & Confidence                      | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|---------------|-------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7.4.1         | <b>INSUFFICIENT_EVIDENCE</b><br>Conf: 80% | <b>Analysis:</b> The policy mentions that consent is used for marketing communications and optional analytics, but it lacks specific statements addressing whether the performance of a contract or service provision is conditioned on consent to processing that is not necessary for the contract.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:3):</i> "Consent — for marketing communications and optional analytics (you can withdraw at any time)" |

### Group 7.3 — Right to withdraw consent (Article 7) | **PARTIALLY\_MET** (Confidence: 95%)

**Identified Gap / Finding:** The policy mentions the right to withdraw consent, but contains no commitment or statement confirming that data subjects will be informed of this right prior to giving consent. The policy does not state that withdrawing consent is as easy as giving consent.

| Obligation ID | Verdict & Confidence        | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                        |
|---------------|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7.3.1         | <b>MET</b><br>Conf: 100%    | <b>Analysis:</b> The policy confirms that users have the right to withdraw consent at any time.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:4):</i> "Where we rely on consent, you have the right to withdraw it at any time by contacting us at <a href="mailto:privacy@techstartup.com">privacy@techstartup.com</a> ." |
| 7.3.2         | <b>MET</b><br>Conf: 100%    | <b>Analysis:</b> The policy explicitly states that withdrawal of consent does not affect the lawfulness of processing prior to withdrawal.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:4):</i> "Withdrawal of consent does not affect the lawfulness of processing that occurred before the withdrawal."                 |
| 7.3.3         | <b>NOT_MET</b><br>Conf: 90% | <b>Analysis:</b> The policy mentions the right to withdraw consent, but contains no commitment or statement confirming that data subjects will be informed of this right prior to giving consent.                                                                                                                              |
| 7.3.4         | <b>NOT_MET</b><br>Conf: 90% | <b>Analysis:</b> The policy does not state that withdrawing consent is as easy as giving consent.                                                                                                                                                                                                                              |

### Group 8.1 — Age threshold for a child's valid consent (Article 8) | **NOT\_APPLICABLE** (Confidence: 100%)

| Obligation ID | Verdict & Confidence                | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|---------------|-------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 8.1.1         | <b>NOT_APPLICABLE</b><br>Conf: 100% | <b>Analysis:</b> The policy states that services are not directed at children under 13 and they do not knowingly collect personal data from children, meaning the applicability condition regarding offering information society services directly to children and relying on consent is not met.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:11):</i> "Our Services are not directed at children under the age of 13. We do not knowingly collect personal data from children." |
| 8.1.2         | <b>NOT_APPLICABLE</b><br>Conf: 100% | <b>Analysis:</b> The policy states that services are not directed at children and they do not knowingly collect personal data from children, meaning the applicability condition regarding offering information society services directly to children and relying on consent is not met.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:11):</i> "Our Services are not directed at children under the age of 13. We do not knowingly collect personal data from children."          |

### Group 8.2 — Reasonable efforts to verify parental consent (Article 8) | **NOT\_APPLICABLE** (Confidence: 100%)

| Obligation ID | Verdict & Confidence                | Reason & Evidence Quote                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 8.2.1         | <b>NOT_APPLICABLE</b><br>Conf: 100% | <b>Analysis:</b> The policy states that services are not directed at children under the age of 13 and that they do not knowingly collect personal data from children. Therefore, parental consent is not relied upon.<br><i>Quote (ed72641b-757e-4b5e-89b9-54815846ce37:11):</i> "Our Services are not directed at children under the age of 13. We do not knowingly collect personal data from children." |

# Priority Action Plan & Remediation Guidance

Categorized recommendations based on identified compliance gaps.

| Priority Level | GDPR Article | Group ID              | Required Remediation Action                                                                                                                                                                                                                                                                                                                |
|----------------|--------------|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| P2 HIGH        | Article 5    | 5.1.quality_retention | Policy provides right to correction but lacks explicit 'prompt' timeframe. Retention periods are defined with legal exceptions but safeguards for extended retention are not explicitly stated.                                                                                                                                            |
| P2 HIGH        | Article 5    | 5.2                   | Policy mentions data retention periods and legal bases for processing, which support accountability. However, there is no explicit evidence of records or documentation demonstrating compliance with Art. 5(1).                                                                                                                           |
| P2 HIGH        | Article 6    | 6.3                   | The policy lists 'Legal obligation — to comply with applicable laws and regulations' as a legal basis, but it does not specifically identify the particular laws establishing the legal basis for processing other than mentioning Indian tax laws (Income Tax Act, 1961 and GST Act, 2017) in the context of retaining financial records. |
| P2 HIGH        | Article 7    | 7.3                   | The policy mentions the right to withdraw consent, but contains no commitment or statement confirming that data subjects will be informed of this right prior to giving consent. The policy does not state that withdrawing consent is as easy as giving consent.                                                                          |